MITRE ATLAS | AML.CS0001 - Botnet Domain Generation Algorithm (DGA) Detection Evasion

Entry Information

ID:
AML.CS0001

Type:
Case-Study

Name:
Botnet Domain Generation Algorithm (DGA) Detection Evasion

URL:
https://atlas.mitre.org/studies/AML.CS0001/

Incident Date:
2020-01-01

Target:
Palo Alto Networks ML-based DGA detection module

Actor:
Palo Alto Networks AI Research Team

Description

The Palo Alto Networks Security AI research team was able to bypass a Convolutional Neural Network based botnet Domain Generation Algorithm (DGA) detector using a generic domain name mutation technique.
It is a generic domain mutation technique which can evade most ML-based DGA detection modules.
The generic mutation technique evades most ML-based DGA detection modules DGA and can be used to test the effectiveness and robustness of all DGA detection methods developed by security companies in the industry before they is deployed to the production environment.

Attack Procedure:
[AML.T0000] Search Open Technical Databases: DGA detection is a widely used technique to detect botnets in academia and industry.
The research team searched for research papers related to DGA detection.
[AML.T0002] Acquire Public AI Artifacts: The researchers acquired a publicly available CNN-based DGA detection model and tested it against a well-known DGA generated domain name data sets, which includes ~50 million domain names from 64 botnet DGA families.
The CNN-based DGA detection model shows more than 70% detection accuracy on 16 (~25%) botnet DGA families.
[AML.T0017.000] Adversarial AI Attacks: The researchers developed a generic mutation technique that requires a minimal number of iterations.
[AML.T0043.001] Black-Box Optimization: The researchers used the mutation technique to generate evasive domain names.
[AML.T0042] Verify Attack: The experiment results show that the detection rate of all 16 botnet DGA families drop to less than 25% after only one string is inserted once to the DGA generated domain names.
[AML.T0015] Evade AI Model: The DGA generated domain names mutated with this technique successfully evade the target DGA Detection model, allowing an adversary to continue communication with their [Command and Control](https://attack.mitre.org/tactics/TA0011/) servers.

References

- Yu, Bin, Jie Pan, Jiaming Hu, Anderson Nascimento, and Martine De Cock. "Character level based detection of DGA domain names." In 2018 International Joint Conference on Neural Networks (IJCNN), pp. 1-8. IEEE, 2018. — http://faculty.washington.edu/mdecock/papers/byu2018a.pdf

- Degas source code — https://github.com/matthoffman/degas